Sicurezza informatica: la percezione e la realtà

Fabio (naif) Pietrosanti - fabio@pietrosanti.it

Sikurezza.org, Italian Security Mailing lists

http://www.sikurezza.org

Webbit04 Milano 4 Giugno 2004

Introduzione

- Internet oggi
- I mali di internet e come vengono percepiti
- Finanza e cybercrime
- Percezione della security
- La sicurezza come processo
- Non solo computer: il social engineering

Internet Oggi

- L’anarchia di internet
- Difficolta’ / Impossibilita’ di tracciamento
- Qualche dato:
  - Fabio.pietrosanti.it: **350+ scan al giorno (67000 con worm)**
  - Aspettativa di vita di linux redhat 6.2: **72ore** (honeynet project)
  - Piu’ veloce **compromissione: 15 minuti** (honeynet project)

I “mali” di internet? (1)

I mali secondo i media:

- Pedofilia (anche gli agenti si sono stufati!)
- Il mito dell’hacker come pericolo della rete
- Truffe(dialer, 128.000 denuncie in 2 anni)
- Violazione del copyright!
- Frodi e furto carte di credito

I “mali” di internet? (2)

I mali veri:

- Riciclaggio di denaro (Digital Money Trust)
- Spionaggio industriale (l’aggressività asiatica)
- Cyber Terrorismo (ancora non ci siamo arrivati)
- Cyber Sabotaggio (DOS, concorrenza sleale)
- Worm (fino ad oggi hanno scherzato!)
- Truffe (Enlarge your penis? Mr. Mudaba!)
- Furto d’identita’ (con il terrorismo si cambia!)

I “mali” di internet? (3)

- Solo una piccola percentuale di cio’ che accade viene rilevato

- Solo una piccola percentuale di questo viene pubblicato sui giornali

- La maggioranza dei fatti non viene resa pubblica (perdita di reputazione ↙ 30% valore società)

Finanza e cybercrime

Influenzare la borsa:

- Disclosure di informazioni riservate
- Pubblicazione di false informazioni (cognitive hacking)
- Furto di informazioni

Attivitá offshore:

- Costituzione assetti societari fantasiosi
- Offshore banking

Percezione della security (1)

Personal security:

- I rischi dell'always on
- Chi vuoi che venga a bucare proprio me???
- eppoi io non ho nulla da nascondere!
- comunque la carta di credito su internet non la uso!

Percezione della security (2)

Enterprise security:

- la sicurezza è un costo
- Ci si pensa quando è troppo tardi
- si considera solo il frontend internet:
  - e neanche tutto (penetration test = 60keuro di sicurezza compromessi in una mattinata!!!)
  - rete interna e internet supersicuri. Ma al marketing non piacciono I cavi di rete = pericolo wifi

La sicurezza come processo

- Protection, Detection, Reaction
- **Sicurezza fisica:**
  - Porta Blindata
  - Telecamere e sensori di movimento
  - Metronotte e polizia
- **Sicurezza logica:**
  - Firewall, PKI, etc, etc
  - Intrusion Detection, analisi log files, etc
  - Network Security Monitoring ↙ Costi

Non solo computer: il social engineering (1)

Definizione:

Metodo per ottenere informazioni mistificando la nostra reale identita' durante la conversazione con un altro essere umano

[Andrea Ghirardini,http://www.blackhats.it/it/papers/social_engineering.pdf]

Non solo computer: il social engineering (2)

Esempi:

1999: Mass social con mailing @tin.it

2002: Penetration test, pila vince 1 a 0

2003: Ci sono problemi con il tuo stipendio

Non solo computer: il social enginering (3)

- 2003: Ci sono problemi con il tuo stipendio

From: Amministrazione
Subject: Ci sono alcuni problemi con il tuo stipendio

Ci sono stati alcuni problemi con i conteggi del tuo stipendio di questo mese.
Abbiamo realizzato questa pagina per visualizzare un riepilogo contenente la revisione dello stipendio e i nuovi conteggi:
http://sito.fittizzio.it/Amministrazione_stipendi.htm
Utilizza username e password che usi per accedere al tuo computer per
visualizzare i tuoi dati.

Grazie e buon lavoro!
L'amministrazione

Ma il problema vero dove sta?

- Mancanza di formazione come naturale conseguenza della transizione nell'era dell'informazione
- Trasposizione delle attività del mondo fisico in quello elettronico senza disporre gli strumenti necessari per valutarne l'impatto sulla società e sull'azienda
- Elitarietà dei tecnologhi
- Sfruttamento dell'ignoranza da parte degli addetti al settore (la sicurezza non e' un prodotto o un servizio facilmente paragonabile qualitativamente)

Per concludere...

Conclusioni

La disumanità del computer sta nel fatto che, una volta programmato e messo in funzione, si comporta in maniera perfettamente onesta.

Isaac Asimov